



UNIDAD 5. FIREWALLS

EE: SEGURIDAD EN REDES DE CÓMPUTO

LIC. EN INGENIERÍA DE CIBERSEGURIDAD E
INFRAESTRUCTURA DE CÓMPUTO

MRT. MARTHA ELIZABET DOMÍNGUEZ BÁRCENAS

Agenda

- Funciones
- Tipos de Firewall
- Tecnologías de Firewall
- Filtrado de paquetes
- Filtrado por dirección
- Filtrado por servicio

Antecedentes

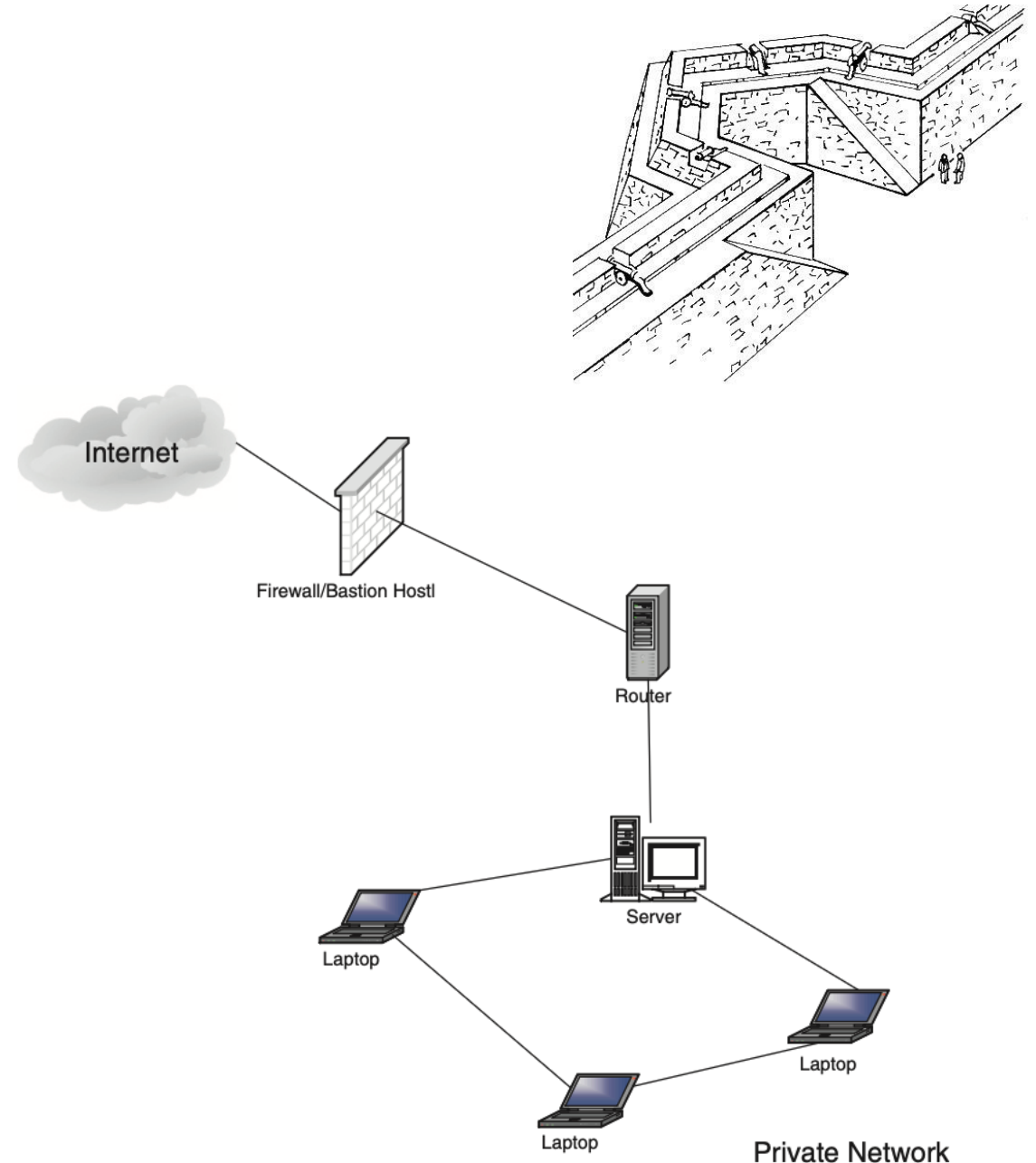
- Los administradores de red enfrentan amenazas en dos sentidos:
 - Usuarios internos
 - Usuarios externos
- Deben encontrar formas de restringir el acceso a la red de la organización o a una sección de esta.
- Uno de estos mecanismos son los Firewalls.

¿Qué es un Firewall?

- Un firewall es un software, hardware o una combinación de ambos que monitorea y filtra tráfico de paquetes que intentan ingresar o abandonar una red protegida.
- Es una herramienta que proporciona un filtro de paquetes entrantes y salientes.
- Es el perímetro de seguridad de la red.
- La primera línea de defensa de la red de una organización que vigila el tráfico entrante y saliente.

Funciones (1/2)

- Filtrado de paquetes por medio de aceptación o denegación, basada en las políticas de seguridad de la organización.
- Proxy gateways que prestan servicios a los usuarios internos y, al mismo tiempo, protegen a cada host individual de los usuarios externos malintencionados



Funciones (2/2)

- Cuando las políticas de la organización son implementadas en un firewall, este debería:
 - Prevenir la entrada e interferencia de intrusos con las operaciones de la red organizacional.
 - Prevenir borrado o modificación de la información ya sea almacenada o en tránsito.
 - Prevenir adquisición de información que es propiedad de la organización.
 - Prevenir mal uso de los recursos de la organización.
 - Proporcionar end-points para las VPN.

Tipos de Firewall (1/2)

- Amplia variedad de servicios
- Pueden ser configurados para proporcionar servicios de seguridad en múltiples capas del modelo TCP/IP

Table 12.1 Firewall services based on network protocol layers

Layer	Firewall services
Application	Application-level gateways, encryption, SOCKS Proxy Server
Transport	Packet filtering (TCP, UDP, ICMP)
Network	NAT, IP-filtering
Data link	MAC address filtering
Physical	May not be available

Tipos de Firewall (2/2)

- Packet inspection o Filtering Router
 - Utiliza un conjunto de reglas para determinar si se envía o bloquea un paquete
 - El packet inspection router podría ser una simple máquina con múltiples interfaces o una máquina sofisticada con múltiples funcionalidades.
- Application inspection o Proxy Server
 - Basado en demonios de aplicación específicos que proporcionan autenticación y reenvío de paquetes.
- Virtual Private Networks (VPN)
 - Enlace cifrado en una red privada, corriendo sobre una red pública.
- Small Office or Home Office (SOHO) Firewall
- Network Address Translation (NAT)

Packet Inspection Firewalls (1/7)

- Routers que inspeccionan el contenido de la dirección origen o destino y los puertos de entrada o salida, de los paquetes que son enviados entre redes.
- Trabaja en la capa de red y es programado para comparar cada paquete con una lista de reglas configuradas a partir de las políticas de seguridad de la organización.
- Decide si un paquete debería pasar, demorarse para una futura inspección o borrarse, comparando las reglas con el contenido del encabezado del paquete.

Packet Inspection Firewalls (2/7)

- Dos tipos de filtrado de paquetes
 - Estático o Filtrado sin estado (Stateless filtering)
 - El paquete es aislado de su contexto.
 - Servidor bastión de comunicación full duplex (permite comunicación en ambos sentidos basada en reglas de filtrado).
 - Las reglas aplican solo a la información contenida en el paquete (encabezado).
 - Filtrado con estado (Stateful filtering)
 - El paquete es filtrado con base en su contexto.
 - Servidor bastión de comunicación full duplex.
 - Por cada paquete, el firewall examina el dato y el estado de la conexión entre cliente y servidor.
 - Este tipo de filtrado analiza el payload de cada paquete.
 - Cada solicitud al servidor es estrictamente inspeccionada contra la base de reglas y registrada por el firewall.

Packet Inspection Firewalls (3/7)

- Filtrado por dirección IP
 - Considera la dirección IP de origen o de destino
 - En un filtrado sin estado no se guarda registro, por lo que el filtro no recuerda paquetes que hayan pasado a través de este. Debilidad que podría ser explotada por hackers al hacer IP-spoofing.
 - Ejemplo:

Application protocol	Source IP	Destination IP	Action
HTTP	Any	198.124.1.0	Allow
Telnet	Any	198.213.1.1	Deny
FTP	Any	198.142.0.2	Allow

Packet Inspection Firewalls (4/7)

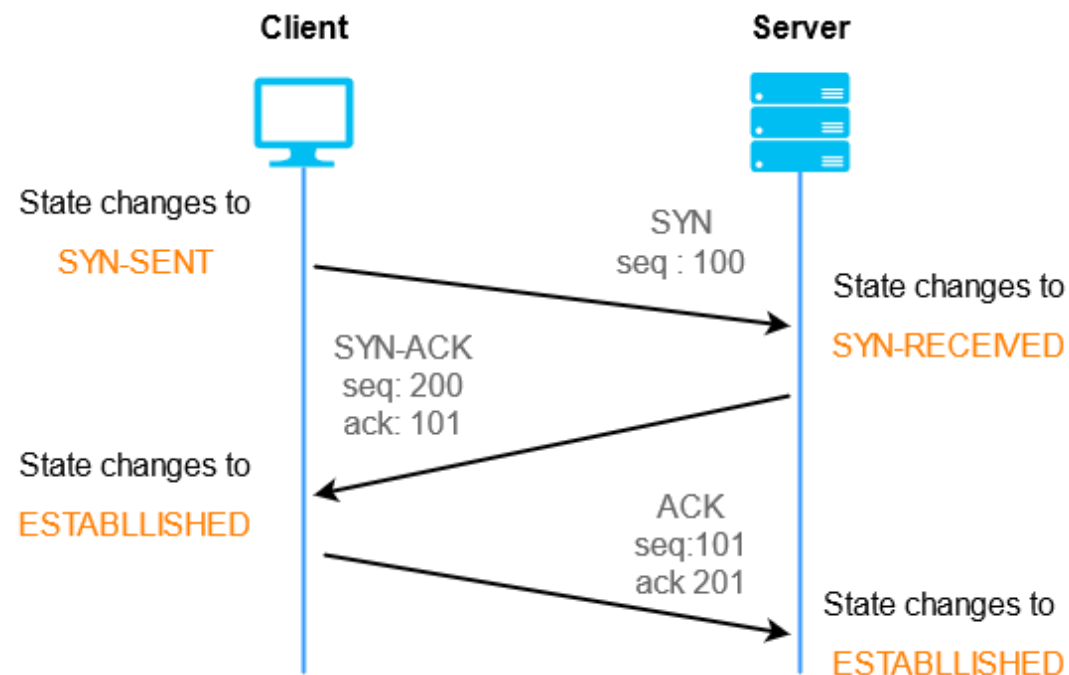
- Filtrado por número de puerto TCP o UDP
 - Proporciona mayor flexibilidad al administrador de sistemas para permitir a usuarios de una red confiable acceder a servicios específicos
 - Ejemplos:

Application	Protocol	Destination port number	Action
HTTP	TCP	80	Allow
SSL	UDP	443	Deny
Telnet	TCP	23	Allow

- Algunos problemas relacionados:
 - Podría desconocerse el puerto en el que corre el servicio al que se intenta acceder.
 - La posibilidad de ajustar los números de puerto para un servicio podría provocar que se admitan paquetes de un intruso (por ejemplo, desde el puerto 80).

Packet Inspection Firewalls (5/7)

- Filtrado basado en los bits de Números de Secuencia Inicial (ISN) y Acuse de Recibo (ACK)
 - Paquetes con ACK=0 indican una solicitud de conexión. ACK <> 0 indica conexión continua.
 - Un firewall puede ser configurado para permitir a paquetes con ACK<>0 acceder solo a puertos específicos y solo en una dirección específica (un hacker podría insertar un ACK<>0 en un paquete).
 - Usando los bits ACK se podrían limitar los tipos de datos entrantes a solo paquetes de respuesta.
 - Ejemplos:



Sequence number	IP Destination address	Port number	ACK	Action
15	198.123.0.1	80	0	Deny
16	198.024.1.1	80	1	Allow

Packet Inspection Firewalls (6/7)

- Algunos problemas asociados:
 - Filtrado de puertos UDP
 - UDP no maneja acuses de recibo, por lo que no se pueden establecer filtros basados en ACK. El administrador no puede controlar donde se originan los paquetes UDP.
 - El filtrado de paquetes no permite controlar ataques como host flooding (DoS)
 - El filtrado de paquetes no permite controlar el tráfico sobre VPN
 - No se ocultan las direcciones de la red interna, lo cual proporciona datos de acceso a los posibles intrusos.

Packet Inspection Firewalls (7/7)

- Firewalls populares:
 - Iptables
 - Herramienta de CLI en linux para configurar el firewall del núcleo.
 - Nftables
 - Sucesor de iptables
 - Sintaxis similar a un lenguaje de programación
 - No evalúa reglas individualmente, utiliza máquina virtual interna que procesa las reglas de forma más eficiente
 - Múltiples acciones en una sola regla
 - Mejor rendimiento de CPU
 - Firewalld
 - Demonio que actúa como interfaz para nftables (o iptables)
 - Estándar en distribuciones basadas en RedHat
 - Permite definir zonas con distintos niveles de confianza
 - UFW (Uncomplicated Firewall)
 - Herramienta por defecto en Ubuntu y Debian
 - Es un wrapper (capa superior)
 - Para configuraciones de red no complejas, como abrir o cerrar puertos

Application Proxy Server (1/6)

- Filtro basado en servicios conocidos
- Definición de filtros para permitir paquetes de servicios bien conocidos y popularmente usados
- Conocidos como proxy servers
- Máquina colocada entre un cliente y un servidor con el recurso deseado. Actúa como servidor para el cliente y como cliente para el servidor.
- Es un intermediario.
- Permite filtrar tráfico basado en una aplicación.
- Permite registrar y controlar todo el tráfico entrante y saliente.
- Podría permitir funciones adicionales como autenticación de usuarios, cifrado punto a punto, ocultación de información y restricciones de acceso basada en tipos de servicio.

Application Proxy Server (2/6)

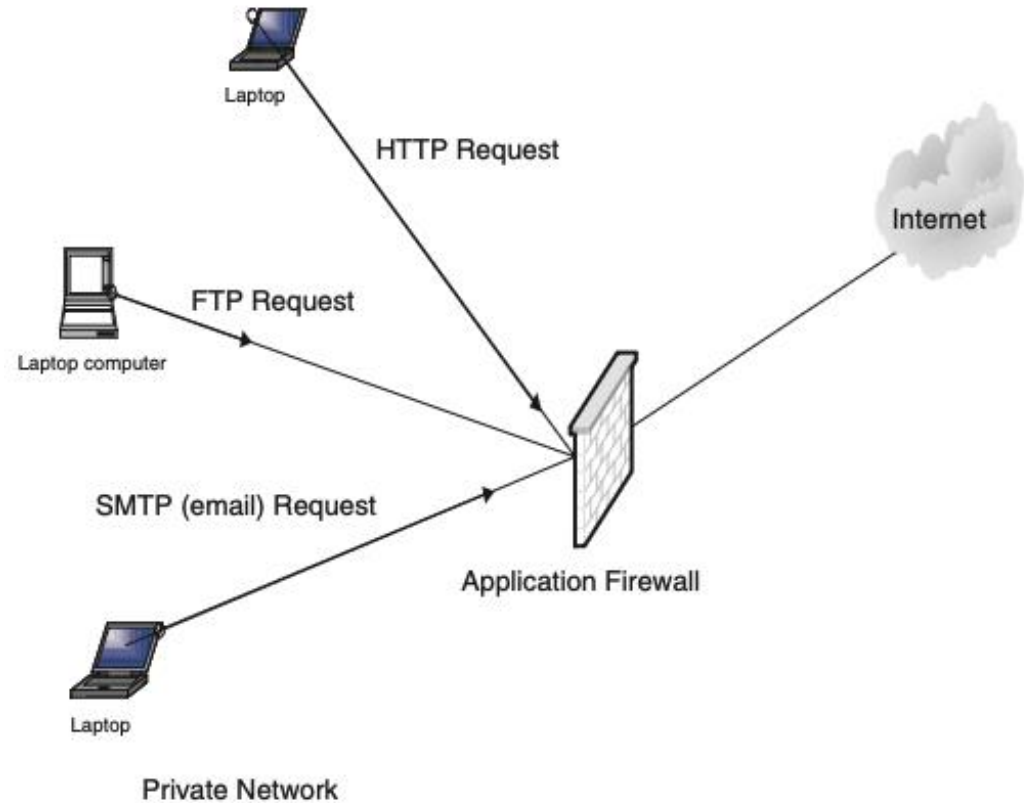
- Intercepta una solicitud de un host de la red interna y luego la pasa a su destino, reemplazando la dirección IP de origen con su propia IP.
- En una recepción del exterior, el proxy reemplaza la dirección destino (la suya) con la dirección IP del host interno correspondiente.
- Ejemplos:
 - Proxy Web: Squid, Blue Coat, Privoxy
 - Proxy inverso (protección de servidores y distribución de carga): NGINX, HAProxy.
 - Proxies de correo electrónico: Cisco Secure Email, SpamAssassin
 - Proxies de base de datos: ProxySQL, pgBouncer.
 - Proxies de Transferencia de archivos: Fox

Application Proxy Server (3/6)

- 3 operaciones básicas:
 - Ocultación de direcciones IP
 - Destrucción del encabezado original
 - Aplicación de protocolos.
 - Dificulta la suplantación de puertos, ya que cada proxy actúa como un servidor para cada host. Al gestionar una sola aplicación, es capaz de detener actividades de suplantación de puertos.

Application Proxy Server (4/6)

- Dos tipos
 - Proxy de Aplicación
 - Proxy SOCKS



Application Proxy Server (5/6)

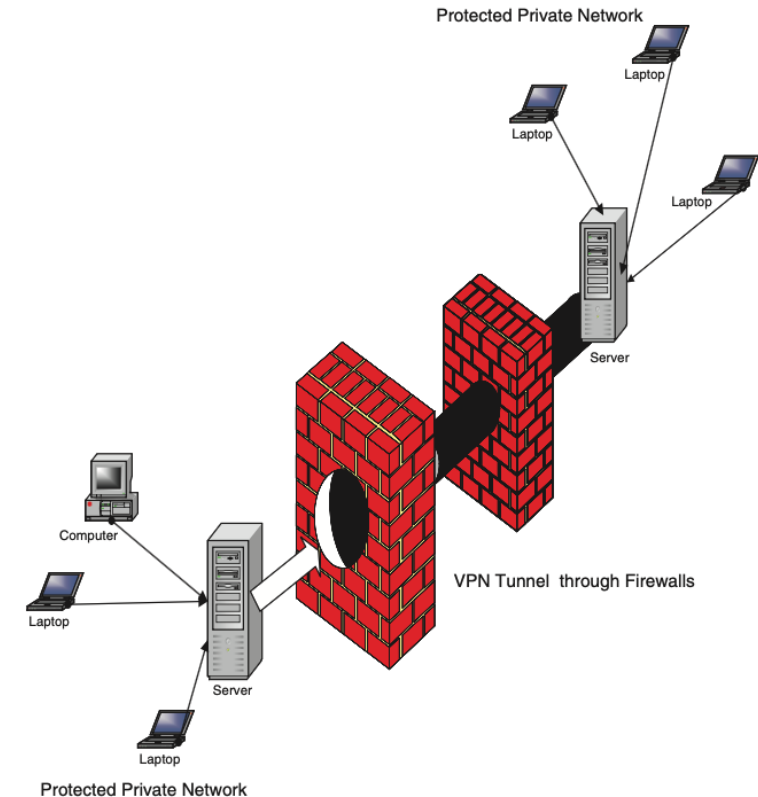
- Proxy de Aplicación
 - Automatizan el proceso de filtrado y reenvío para el cliente.
 - Cliente contacta al firewall, el proxy hace la solicitud correspondiente y si recibe respuesta, la regresa al cliente.
 - Puede guardar registro del proceso, por ejemplo, todas las URL visitadas y archivos descargados.
 - Puede utilizar filtros de lenguaje para contenido inapropiado.
 - Puede autenticar usuarios y aplicaciones mediante mecanismos que incluyen contraseñas de un solo uso (OTP)
 - Dos modelos:
 - Modelo de Seguridad positiva
 - Política inicial basada en una lista de condiciones iniciales
 - El firewall examina las solicitudes de servicio en detalle.
 - Si la solicitud no cumple con las condiciones, se rechaza
 - Se crea una nueva política para cada nueva sesión.
 - Modelo de Seguridad Negativa
 - Parte de una base de datos predefinida de firmas “no aceptables” (ataques conocidos)
 - Los ataques conocidos son bloqueados y los no conocidos (buenos o malos) se asumen como solicitudes válidas.
 - Todos los usuarios comparten la misma política.

Application Proxy Server (6/6)

- SOCKS Proxy
 - Demonio de nivel de circuito
 - Tiene capacidades limitadas. Solo permite paquetes originados en fuentes no prohibidas, sin analizar el contenido del paquete.
 - Son más rápidos que los proxies de nivel de aplicación.
 - No analizan contenido del paquete
 - No proporcionan autenticación de usuarios, pero pueden registrar y hacer seguimiento de la actividad del usuario. Por ejemplo, para saber a donde se conectó.

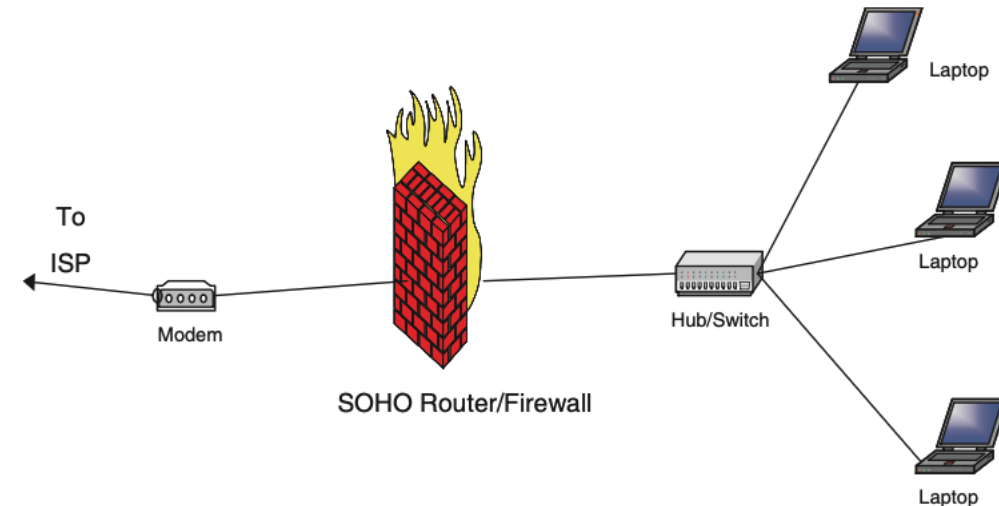
VPN Firewall

- Sistema criptográfico que transporta frames a través de Internet con múltiples enlaces de datos y seguridad agregada.
- Se puede crear utilizando una simple computadora remota conectada a la red confiable (VPN de acceso remoto) o conectando dos sitios de red corporativos (VPN sitio a sitio).
- El servidor VPN también puede actuar como firewall.
- Ventajas:
 - Cifrado de conexiones
 - Conexiones limitadas a máquinas con direcciones específicas.



Small Office or Home (SOHO) Firewall

- Firewall relativamente pequeño que conecta algunas computadoras personales a través de un hub o un switch, hacia un modem de banda ancha, como DSL o cable.
- Configuración típica para una pequeña oficina o para el hogar.
- Evita que se conozcan las direcciones internas a través de NAT y realizando peticiones en nombre de todos los host internos.



Consideraciones para la configuración e implementación de un Firewall (1/2)

- Dos enfoques:
 - Empezar de cero y obtener información para espablecer las necesidades y requisitos de la organización.
 - Mayor consumo de tiempo y probablemente de recursos*
 - Instalación de un firewall de un proveedor, equipado con numerosas funciones.
 - El administrador elige las características que reúnen las necesidades y requisitos establecidos de la organización.

Consideraciones para la configuración e implementación de un Firewall (1/2)

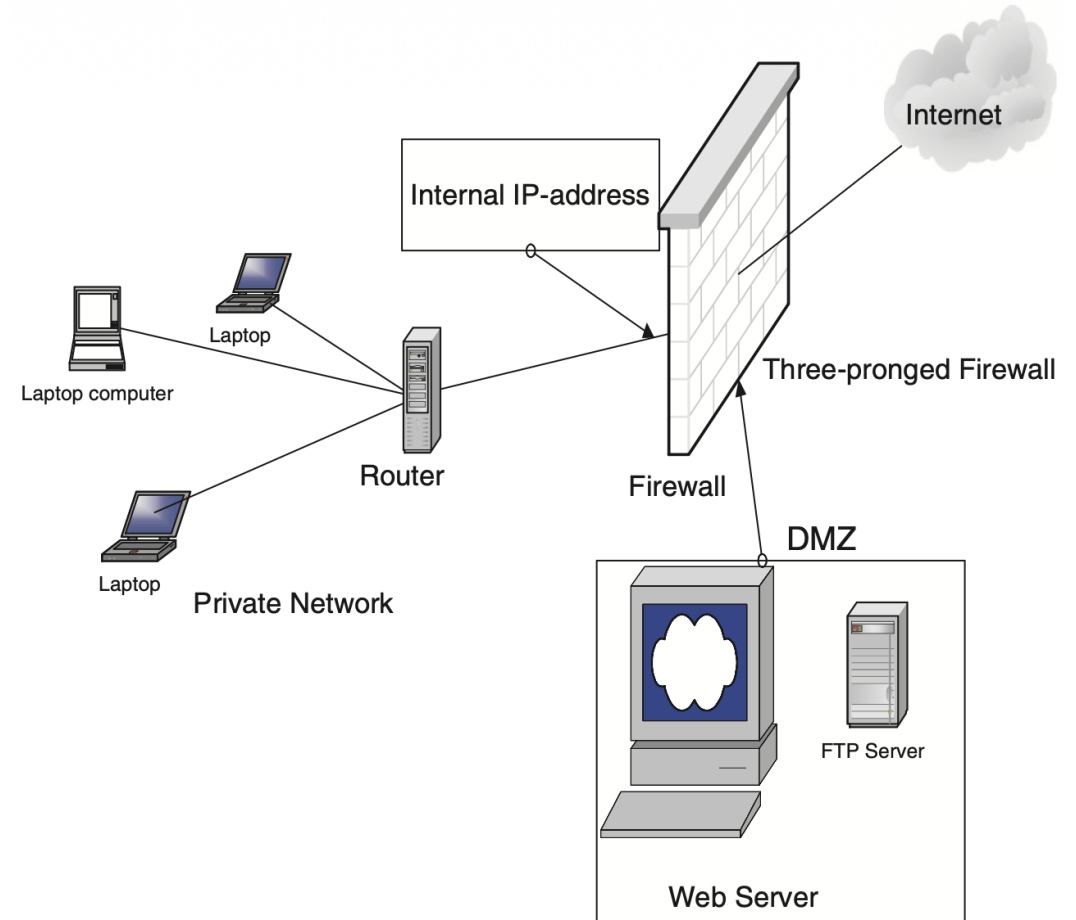
- En cualquier caso se debe considerar:
 - **Capacidad técnica.** ¿La tiene la organización o es necesario contratar a un externo?
 - **Revisión de seguridad.** Antes de la instalación deben existir políticas de seguridad que permitan elaborar una lista priorizada de objetivos de seguridad.
 - **Requisitos de auditoría.** Basados en las políticas de seguridad, definir la frecuencia de las auditorías y lo que debe incluirse en las mismas (por ejemplo, grado y detalles de registro).
 - **Requisitos de filtrado y rendimiento.** Decidir cual es el equilibrio adecuado entre seguridad y rendimiento para la organización. Esto permitirá establecer el nivel de filtrado que permita alcanzar ese equilibrio.
 - **Autenticación.** Decidir si es necesaria y de ser así, implementarla.
 - **Acceso remoto.** Si es necesario, incluir requisitos de autenticación y cifrado de las sesiones. Considerar el uso de VPN.
 - **Requisitos de aplicación y de red.** Decidir el tipo de tráfico de red a ser soportado (NAT, ruteo estático, ruteo dinámico, etc.)
 - **Decidir el tipo de cortafuegos.** Dependerá del tipo de servicios que vaya a ofrecer la organización.

Zona Desmilitarizada (DMZ)

- Se llama así a un segmento de red entre la red protegida y la red externa
- También conocida como la red de servicios
- Propósito: Proporcionar algo de aislamiento y seguridad extra a servicios que provee la organización, tales como HTTP/HTTPS, FTP, DNS o SMTP, al público.

Zona Desmilitarizada (DMZ)

- Acceso seguro y limitado para la red interna.
- Restricciones de acceso para la red externa, pero no tan estrictas como para la red protegida
- Los externos pueden acceder a los servicios de la organización en la DMZ
- Los servidores tienen un gran potencial de ataque.
- Dichas máquinas deben protegerse de usos inadecuados desde la red interna y desde la externa.
- Aislados por cortafuegos desde ambos lados de la DMZ.
 - Más permisivo hacia el exterior
 - Más restrictivo hacia la red interna



iptables

Filtrado de paquetes con IPTABLES

- Netfilter. Parte del núcleo de linux que permite gestionar el flujo de paquetes
- Iptables - interfaz de usuario para gestionar netfilter (requiere ser root)
- Consiste en una serie de reglas organizadas en tablas (tables)
- Cada table a su vez, organiza sus reglas en cadenas (chains)
- Las reglas implican acciones con los paquetes involucrados (target)
- Los paquetes se validan regla por regla, en orden consecutivo.

TABLE 1

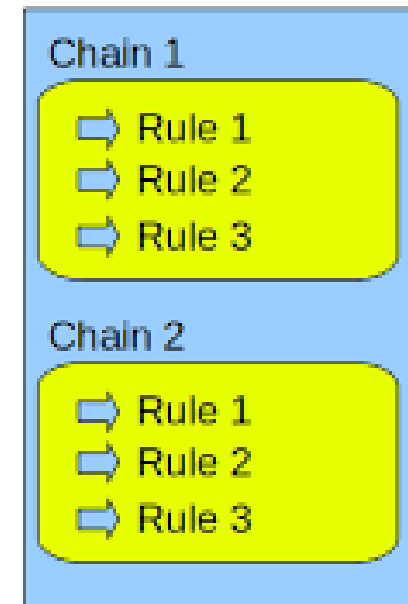
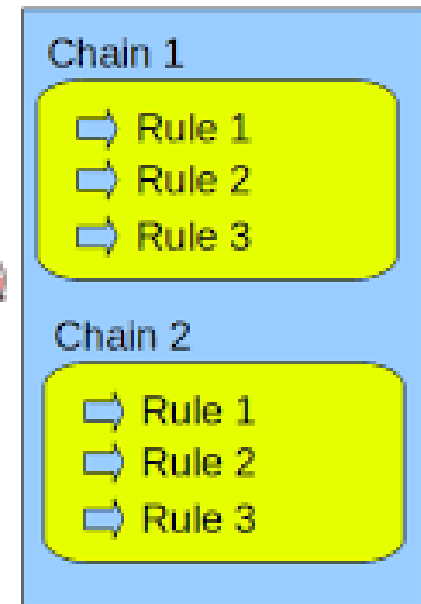


TABLE 2



CHAINS

- INPUT. Filtra paquetes dirigidos al host.
 - Ejemplo: ping dirigido al host
- OUTPUT. Filtra paquetes salientes desde el host.
 - Ejemplo: acceso a sitio web desde el host
- FORWARD. Filtra paquetes enrutados a través del host.
 - Conecta al menos dos redes, internet y la red local
- PREROUTING. Port forwarding (DNAT)
- POSTROUTING. MASQUERADE (SNAT)
- El usuario puede crear sus propias cadenas

TABLES

- **filter.**
 - Tabla por defecto
 - No hay regla por defecto al final de las cadenas, solo se realiza lo que especifican las reglas
 - Incluye chains: INPUT, OUTPUT, FORWARD
- **nat**
 - Tabla especializada para Source NAT (SNAT) y Destination NAT (DNAT) (Port Forwarding)
 - Incluye las chains: PREROUTING, POSTROUTING y OUTPUT
- **mangle**
 - Especializada en alteración de paquetes. Ejemplo: modificación de los valores de campos en los encabezados (p.e. QoS)
 - Incluye chains: PREROUTING, INPUT, FORWARD, OUTPUT, POSTROUTING
- **raw**
 - El firewall es stateful. Los paquetes se evalúan en función de su relación con los paquetes anteriores
 - Iptables considera los paquetes como parte de una conexión o sesión en curso, en lugar de como un flujo de paquetes independientes y sin relación entre sí.
 - La tabla «raw» se utiliza para marcar los paquetes que no deben ser gestionados por el sistema de seguimiento de conexiones o, dicho de forma sencilla, para indicar que no queremos que algunos paquetes sean clasificados, aceptándolos directamente.
 - Ejemplo: tráfico de las interfaces de loopback
 - Incluye chains: PREROUTING y OUTPUT

Sintaxis

- ***iptables [-t table] -COMMAND CHAIN_NAME matches -j TARGET***

Targets o acciones básicas

- *ACCEPT*
- *DROP*

Matches o coincidencias

- -p, --protocol (TCP, UDP, ICMP o valores enteros: 6, 17 o 1 respectivamente)
- --sport, --source-port PUERTO O RANGO (22:80)
- --dport, --destination-port PUERTO O RANGO
- -s, --src, --source DIRECCIÓN_IP o RANGO (192.168.1.0/24)
- -d, --dst, --destination
- -i, --in-interface INTERFAZ
- -o, --out-interface INTERFAZ

Comandos u opciones

- En mayúsculas
- -A. Para agregar una regla (table filter)
 - Ejemplo: **iptables -A INPUT -p tcp -dport 80 -j DROP**
- -I. Para insertar una regla al inicio o en la posición indicada
 - Ejemplos:
 - `iptables -I INPUT -p udp -dport 69 -j DROP` – Agrega regla al inicio de la cadena INPUT
 - `iptables -I INPUT 3 -p udp -dport 69 -j DROP` – Agrega regla justo en la posición 3
- -L. Lista las reglas de todas las tablas (por defecto filter)
 - Probar con -n y -v
 - Se puede especificar la cadena o la table
- -F. Borra las tablas
 - Se puede especificar la cadena (tabla filter): `iptables -F INPUT`
 - Se puede especificar la tabla: `iptables -t nat -F`

...Comandos u opciones

- -Z. Reinicia contadores de paquetes y de bytes que han hecho match
- -N. Permite crear tus propias cadenas. Ejemplo: iptables -N MICADENA
- -X. Permite borrar las cadenas del usuario. Ejemplo: iptables -X MICADENA
- -P. Permite indicar como se tratarán los paquetes de una cadena que no coincidan con ninguna de las reglas previamente definidas (por defecto, accept). Ejemplo: iptables -P FORWARD DROP
- -D. Permite eliminar una regla específica de una cadena específica.
 - Ejemplo: iptables -D OUTPUT 2 – Borra la Segunda regla de la cadena OUTPUT

Recomendaciones

- Crear script con todas las reglas.
Si hay que eliminar algo, utilizar -F y Volver a ejecutar script.
- Agregar al inicio del script:
 - iptables -F (incluyendo: iptables -t nat -F)
- Ejemplo de script para limpiar firewall:

```
#!/bin/bash
```

```
#1. Set the ACCEPT POLICY an all CHAINS
```

```
iptables -P INPUT ACCEPT
```

```
iptables -P OUTPUT ACCEPT
```

```
iptables -P FORWARD ACCEPT
```

```
#2. Flush all tables from all CHAINS
```

```
iptables -t filter -F
```

```
iptables -t nat -F
```

```
iptables -t mangle -F
```

```
#3. Delete user-defined CHAINS (if there is any)
```

```
iptables -X
```

Reglas Persistentes

- Las reglas se almacenan en memoria RAM.
- Para conservarlas aún después de reiniciar el sistema, es necesario hacerlas persistentes
 - Instalar **iptables-persistent**
 - `iptables-save > /etc/iptables/rules.v4`

NAT

- Network Address Translation implica “re-escribir” la dirección origen y/o destino de los paquetes cuando pasan a través del router
- SNAT o Source NAT es la más utilizada
 - Consiste en “convertir” la dirección de un host dentro de la red privada en la dirección real del firewall.
- DNAT o Destination NAT
 - “Cambia” la dirección IP destino de los paquetes entrantes, para redirigir el tráfico externo a servidores internos.

NAT

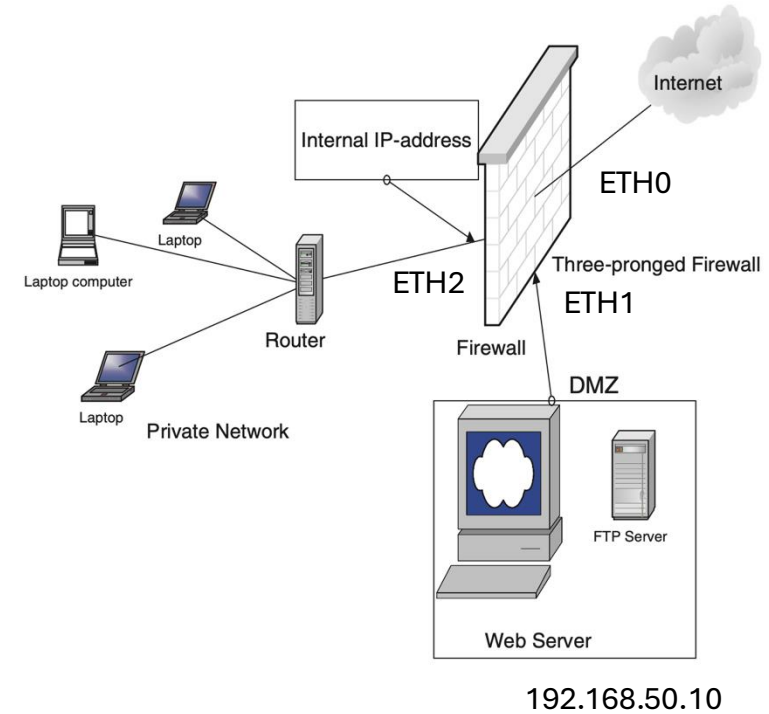
- Requiere un número apropiado de interfaces de red (al menos 2) para habilitar las capacidades de ruteo.
- SNAT utiliza la TABLA nat y la cadena POSTROUTING
- Target MASQUERADE.
 - Recomendado cuando la dirección pública del router es dinámica
 - Automáticamente usa la IP de la interfaz externa para la traducción.
- Implica Traducción de Direcciones de Puerto (PAT)

Ejemplo NAT

- `iptables -t nat -A POSTROUTING -s 10.0.0.0/24 -o eth0 -j SNAT --to-source 80.0.0.1`
- `iptables -t nat -A POSTROUTING -s 10.0.0.0/24 -o eth0 -j MASQUERADE`
- Configuración previa requerida:
 - **Echo "1" > /proc/sys/net/ipv4/ip_forward**
 - Editar `/etc/sysctl.conf` y agregar **net.ipv4.ip_forward=1** y reiniciar servicio de red (`systemctl restart networking`)

Destination NAT (DNAT)

- Redirige el tráfico externo a servidores internos.
- Permite crear zonas desmilitarizadas (DMZ)
- Requiere el uso de la tabla nat y la cadena PREROUTING
- Ejemplo:
 - `iptables -t nat -A PREROUTING -i eth0 -p tcp --dport 80 -j DNAT --to-destination 192.168.50.10:80`
 - `iptables -A FORWARD -i eth0 -o eth1 -p tcp --dport 80 -d 192.168.50.10 -j ACCEPT`



ACTIVIDAD

- Agrega a tu topología con la implementación de NAT, una zona desmilitarizada en la que haya un servidor Web.
- Las redes externas deben poder acceder al servicio Web
- El servidor Web no debe tener acceso a la red interna, sin embargo, desde la red interna si se debe poder acceder vía SSH al servidor Web y a la página correspondiente.

Referencias

- Migga Kizza, J. (2009). A Guide to Computer Network Security. Springer.
- *Abdreasson, Oskar. (2006). Iptables Tutorial 1.2.3.*
<https://www.frozentux.net/iptables-tutorial/iptables-tutorial.html#TARGETS>